

Le point du RSSI : Chiffrer le coût de l'inaction

✓ La question budgétaire qui décide de tout le reste



Objectifs de la séance

À l'issue de cette séquence :

- **Expliquer** ce qu'est le coût de l'inaction et pourquoi il est l'argument central d'une demande d'investissement en sécurité
- **Décomposer** l'impact financier d'un risque en ses composantes documentables : interruption, remédiation, sanctions, atteinte à la confiance
- **Mobiliser** des coûts d'incidents réels, sourcés et datés, sans leur faire dire plus qu'ils ne disent

- **Construire** une justification d'investissement honnête pour le Comité de Direction, adossée au registre de risques de la filiale instruite

Prérequis

- L'étude EBIOS RM de la filiale instruite dans CISO Assistant : les trois couples source de risque / objectif visé retenus en séance 5, sur la filiale instruite et sa dépendance inter-filiale du §6 du dossier de filiale, les scénarios stratégiques ajoutés en séance 6 et le premier scénario opérationnel, déjà coté en vraisemblance ; les suivants seront cotés cet après-midi.
- Les scénarios stratégiques et le premier scénario opérationnel construits en séance 6, avec les parties prenantes critiques de l'écosystème.
- L'appétence au risque formulée en séance 5 : la ligne d'acceptation que la Direction Générale a été appelée à confirmer.
- La gouvernance de séance 1 : le Comité de Direction, le COMEX (comité exécutif) dans le vocabulaire courant des entreprises, fixe les priorités budgétaires, et c'est à lui que s'adresse le travail de ce matin.

Ce qu'il faut savoir avant l'exercice

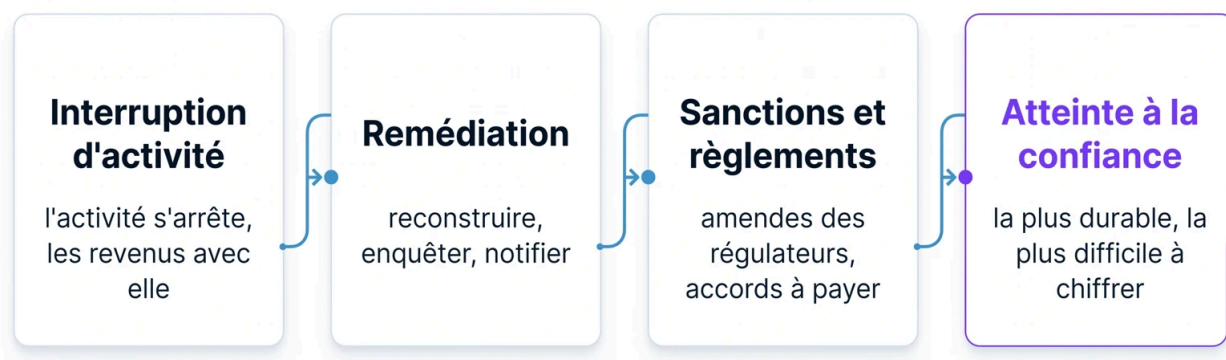
Trois notions suffisent ce matin, et elles préparent directement la journée : cet après-midi, le registre sera coté et le plan de traitement chiffré en effort ; il faudra bien qu'en face, quelqu'un paie. Ce quelqu'un décide mieux quand on lui montre ce que coûte le refus.

D'abord le problème. Depuis la séance 6, le groupe sait ce qu'il craint et par où cela passerait. Mais une direction n'arbitre pas entre des scénarios, elle arbitre entre des dépenses : la mesure de sécurité proposée cet après-midi sera comparée, explicitement ou non, à ce que coûte le fait de ne rien faire. **Le coût de l'inaction**, c'est cette seconde branche de l'alternative : l'ensemble des pertes plausibles que l'organisation supporterait si un risque identifié se réalisait sans que rien n'ait été investi pour le réduire. Sa mécanique : on ne l'invente pas, on le documente, en s'appuyant sur les coûts d'incidents comparables publiés par des sources fiables, et on le rattache à un scénario précis du registre, jamais à la peur en général. Sa limite, à connaître avant d'argumenter : c'est une estimation de plausibilité, pas une prédiction ; personne ne sait ce que coûtera l'incident du groupe, et un RSSI qui promet un chiffre exact perd sa crédibilité à la première contre-question.

L'impact financier d'un risque, ensuite, se décompose, et c'est cette décomposition qui rend le chiffrage honnête. Quatre composantes reviennent dans les incidents documentés. L'interruption d'activité : l'armateur A.P. Moller-Maersk a chiffré dans sa communication financière un impact de 250-300 millions de dollars sur ses activités Transport & Logistics au troisième trimestre 2017, après le malicieux destructeur NotPetya ; le métallurgiste Norsk Hydro évalue sur son site le coût total de la cyberattaque de mars 2019 à environ 800 millions de couronnes norvégiennes, après des estimations trimestrielles successives. La remédiation : reconstruire, enquêter, notifier, ces coûts se lisent dans les mêmes communications. Les sanctions et règlements : Equifax, dont la violation de 2017 avait touché environ 147 millions de personnes, a conclu en 2019 un règlement d'au moins 575 millions de dollars avec le régulateur américain et cinquante États ; en France, la CNIL a sanctionné France Travail de 5 millions d'euros en janvier 2026 pour ne pas avoir assuré la sécurité des données des demandeurs d'emploi, après

la fuite de 2024 qui pouvait toucher 43 millions de personnes. Et la confiance : la plus difficile à chiffrer, la plus durable à réparer, celle que les communications financières ne détaillent jamais complètement.

L'impact financier d'un risque



À côté des cas singuliers, il existe des moyennes de référence. Le rapport Cost of a Data Breach d'IBM mesure chaque année le coût moyen d'une violation de données : en France, 3,95 millions d'euros en 2022, 3,75 millions d'euros en 2023, puis 3,85 millions d'euros en 2024 ; au niveau mondial, 4,44 millions de dollars dans le rapport 2025, en baisse pour la première fois en cinq ans. Le même rapport 2025 mesure le cycle de vie moyen d'une violation, identification et confinement compris, à 241 jours. Ces moyennes ont un usage précis : donner un ordre de grandeur quand aucun cas comparable ne colle au scénario étudié. Et une limite tout aussi précise : une moyenne écrase la dispersion. Le groupe ne subira jamais « le coût moyen » ; il subira son incident à lui, qui peut coûter dix fois moins ou dix fois plus.

**3,85
millions
d'euros**

COÛT MOYEN D'UNE
VIOLATION DE DONNÉES EN
FRANCE EN 2024

IBM, Cost of a Data Breach Report 2024

4,44 M\$

COÛT MOYEN MONDIAL D'UNE
VIOLATION DE DONNÉES,
PREMIÈRE BAISSSE EN CINQ
ANS

IBM, Cost of a Data Breach Report 2025

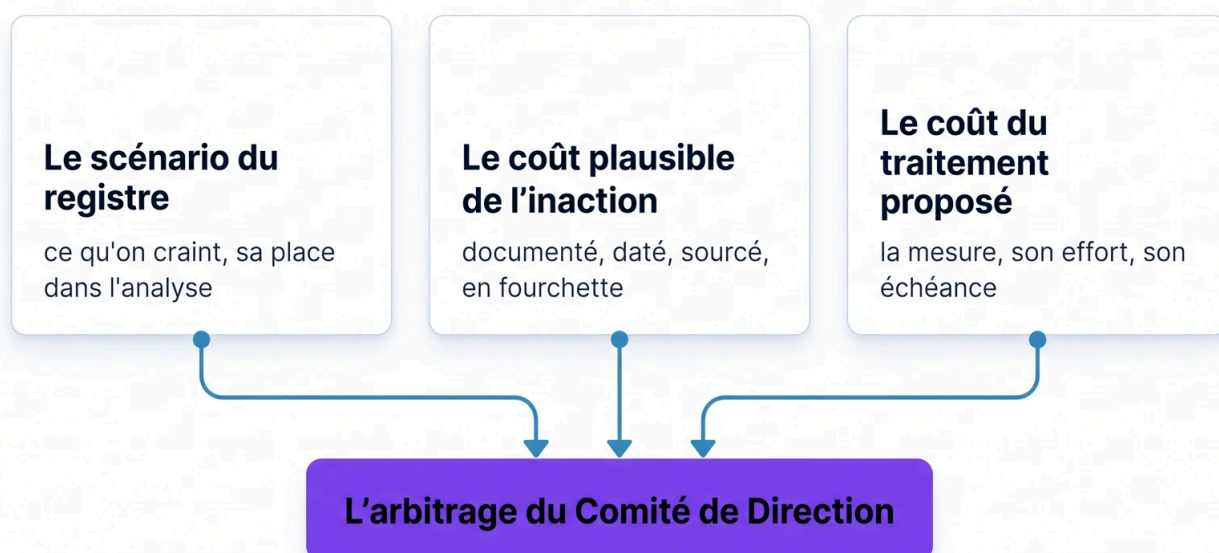
241 jours

CYCLE DE VIE MOYEN
MONDIAL D'UNE VIOLATION,
IDENTIFICATION ET
CONFINEMENT COMPRIS

IBM, Cost of a Data Breach Report 2025

La justification des investissements, enfin, est l'art d'assembler tout cela en un argument que le Comité de Direction peut trancher. Sa forme canonique tient en trois pièces : le scénario du registre (ce qu'on craint, avec sa place dans l'analyse), le coût plausible de l'inaction (documenté, daté, sourcé, en fourchette), et le coût du traitement proposé : la mesure, son effort, son échéance, et son coût annuel, en distinguant ce qui s'investit une fois, le build, une dépense d'investissement (CAPEX, capital expenditure), de ce qui se paie chaque année, le run, une dépense de fonctionnement (OPEX, operational expenditure) ; c'est cet après-midi, dans l'outil, que ce coût se chiffre. La décision devient alors un arbitrage entre deux nombres de natures différentes, un coût certain et modeste contre une perte incertaine et potentiellement lourde, et c'est exactement le type d'arbitrage qu'une direction sait faire, parce qu'elle le fait sur tous ses autres risques. Ce que la justification ne fait pas : elle ne calcule pas un retour sur investissement précis, car la sécurité produit des incidents évités, qui ne se mesurent pas. Un argument qui promet « cette mesure rapportera tant » est une fiction comptable ; un argument qui dit « voici ce que des organisations comparables ont perdu, voici ce que coûte la mesure, voici notre appétence » est une aide à la décision.

La fourchette du coût de l'inaction, en quatre termes. Perte par jour d'arrêt, multipliée par une durée, plus la remédiation, plus la sanction éventuelle. La perte par jour vient du dossier de filiale : pénalités contractuelles, chiffre d'affaires bloqué, avoirs dus. La durée se prend deux fois : basse, la panne que la filiale a déjà vécue ; haute, ce que les cas documentés montrent, des jours à des semaines de mode manuel. La remédiation, reconstruire, enquêter, notifier, se prend au dossier si l'éditeur ou l'hébergeur l'a chiffrée ; sinon la moyenne IBM sert d'ordre de grandeur, dit comme tel. La sanction ne s'ajoute que si des données personnelles sont en jeu, à l'ordre de grandeur de France Travail. Ce qui manque au dossier se demande au Directeur Financier, nommément : une fourchette honnête dit ce qu'elle ne sait pas.



💡 Réflexe de méthode : chaque chiffre porté devant une direction doit répondre à trois questions en une phrase : de qui vient-il, de quelle année date-t-il, et à quoi de notre registre se rattache-t-il. Un chiffre qui échoue à l'une

des trois n'entre pas dans le dossier. C'est la même discipline de sourçage que pour les livrables, appliquée à l'oral.

✓ Cas pratique : trois arguments pour le Comité de Direction

Mise en situation et énoncé

Lundi matin. Le bilan de mi-parcours transmis en fin de séance 6 a montré au Comité de Direction l'état du dossier MERIDIAN, et la réaction ne s'est pas fait attendre : le Directeur Financier a demandé, en marge de la séance, « combien tout cela va nous coûter, et surtout, combien coûte le fait de ne rien faire ? ». La question est une chance : c'est celle qui ouvre les budgets, à condition d'y répondre avec des faits.

Le RSSI Groupe est le point de vue de ce cas. Son étude EBIOS RM porte les trois couples source de risque / objectif visé retenus en séance 5 pour la filiale instruite et sa dépendance inter-filiale du §6 du dossier de filiale, et les scénarios qui en découlent depuis la séance 6. Les scénarios stratégiques de la séance 6 ont montré par où passerait celui qui vise la disponibilité de l'actif critique de la filiale : par les tiers qui interviennent à distance sur cet actif (§3 et §6 du dossier de filiale). Cet après-midi, ces risques seront cotés et le plan de traitement bâti. Ce matin se préparent les arguments financiers qui le feront financer.

Questions guidées

1. **Rattacher** les références de coût aux scénarios du registre de la filiale instruite : un tableau, une ligne par scénario (indisponibilité de l'actif critique, vol ou fuite de données personnelles, malveillance ou erreur interne), avec la référence documentée de l'exposé qui l'éclaire le mieux, la nature du coût qu'elle illustre, le montant, l'année, la source, et une phrase qui dit pourquoi elle éclaire ce scénario-là. Quand aucune référence ne colle, l'écrire dans la ligne : c'est une réponse.
2. **Rédiger** l'argument d'investissement pour le scénario d'indisponibilité de l'actif critique de la filiale instruite. Il s'ouvre par la phrase de réponse au Directeur Financier, une seule, qui pose l'alternative sans dramatiser ni minimiser. Il se poursuit en trois pièces : le scénario et son chemin ; le coût plausible de l'inaction, en fourchette basse et haute, calculée avec les quatre termes du cadrage, perte par jour d'arrêt tirée du dossier de filiale, durée basse et haute, remédiation, sanction éventuelle, et bornée par les références de l'exposé ; quand le dossier ne chiffre pas un terme, nommer la donnée à demander au Directeur Financier ; la nature du traitement qui sera proposé cet après-midi, en disant déjà ce qui s'investira une fois et ce qui se paiera chaque année, sans le chiffrer encore.
3. **Répondre** au contre-interrogatoire du Directeur Financier : formuler les trois objections qu'il opposera à l'argument, telles qu'il les dirait, et pour chacune la réponse du RSSI Groupe en une phrase, appuyée sur une pièce du dossier de filiale ou sur l'échelle de gravité du groupe, jamais sur une promesse.

Méthode de travail

Compter 15 minutes pour la question 1, 20 minutes pour la question 2, 10 minutes pour la question 3. S'interdire tout chiffre qui ne vient pas de l'exposé ou du dossier de filiale : l'exercice évalue la discipline de sourçage autant que l'argumentation. Et garder en tête la nature de l'auditoire : un Directeur Financier respecte une fourchette honnête, se méfie d'une précision suspecte, et respecte plus encore un RSSI qui a anticipé ses objections.



Corrigés et critères d'évaluation – cliquer pour révéler